COMPLETE MVP DEVELOPER PACKAGE · V2.0

Evolve Edge
Developer Handoff Document

Seven integrated deliverables — Permission Matrix, Tier Comparison, Gantt Schedule, API Specifications, User Story Cards, Testing Checklists, and Risk Assessment — compiled into a single production-ready handoff package.

VERSION	DATE	STATUS
2.0	March 2026	Ready for Handoff

STACK	TIMELINE
Next.js · FastAPI · AWS	8 Weeks to MVP

DOCUMENT CONTENTS

1. Role-Based Permission Matrix — Admin · Coach · Athlete (9 modules)
2. Subscription Tier Comparison — Free vs Premium (8 feature categories)
3. 8-Week Development Gantt Chart — Phases, Milestones & Dependencies
4. API Endpoint Specifications — Athlete Profile, Workout Logging & Progress
5. User Story Cards — 33 Stories across 9 Feature Modules
6. Testing Checklist — 120+ Tests organised by Milestone Gate
7. Risk Assessment — 20 Risks across Technical, Timeline, Budget & Security

Role-Based Permission Matrix

Defines exactly what Admin, Coach, and Athlete roles can view, create, edit, and delete across every application module.

Legend: ✓ Full access · ✗ No access · **Cond.** Conditional / scoped (see note in cell)

Authentication & Account Management

Action	Admin	Coach	Athlete
Register account	✓	✓	✓
Login / Logout	✓	✓	✓
Reset own password	✓	✓	✓
Enable / disable MFA (own account)	✓	✓	✓
View & edit own profile	✓	✓	✓
Social login (Google / Microsoft)	✓	✓	✓
Close own account	✓	✓	✓
Reopen / restore any account	✓	✗	✗
Force logout another user	✓	✗	✗

User Management

Action	Admin	Coach	Athlete
View all users — platform-wide	✓	✗	✗
Invite new Coach	✓	✗	✗
Invite new Athlete	✓	**Own roster only**	✗
Edit any user profile	✓	✗	✗
Assign / change user roles	✓	✗	✗
Deactivate / archive user	✓	✗	✗
Delete user account (soft-delete)	✓	✗	✗
View & manage own athlete roster	✓	✓	✗
View coach list (platform-wide)	✓	✗	✗

Athlete Profiles

Action	Admin	Coach	Athlete
View all athlete profiles	✓	✗	✗
View assigned athletes' profiles	✓	✓	✗
View own profile	✓	✓	✓
Edit any athlete profile	✓	✗	✗
Edit assigned athlete's profile	✓	Assigned only	✗
Edit own profile	✓	✓	✓
Add / update biometric data	✓	Assigned only	Own only
Set athlete goals	✓	Assigned only	Own only
Export athlete profile as PDF	✓	Assigned only	Own only

Workout Library & Exercise Database

Action	Admin	Coach	Athlete
View global exercise library	✓	✓	✓
Create new exercise	✓	✓	✗
Edit any exercise	✓	✗	✗
Edit own created exercise	✓	✓	✗
Delete any exercise	✓	✗	✗
Upload exercise media (video / image)	✓	✓	✗
Create workout template	✓	✓	✗
Edit / delete own workout template	✓	✓	✗
Edit any workout template	✓	✗	✗
View assigned / all templates	✓	✓	Assigned only
Duplicate / clone a template	✓	✓	✗
Tag & categorise templates	✓	✓	✗

Workout Assignment & Scheduling

Action	Admin	Coach	Athlete
Assign workout to athlete	✓	Own roster only	✗
Schedule workout with date/time	✓	✓	✗
View own assigned schedule	✓	✓	✓
View athlete's assigned schedule	✓	Own roster only	✗
Modify / cancel assigned workout	✓	Own roster only	✗
Set recurring workout schedule	✓	✓	✗
Mark rest / recovery day	✓	✓	Own only

Workout Logging

Action	Admin	Coach	Athlete
Log own workout session	✓	✓	✓
Log workout on behalf of athlete	✓	Own roster only	✗
Edit own log entry (unlimited)	✓	✓	✗
Edit own log entry (Free — 24 hrs)	✓	✓	Own within 24 hrs
Edit athlete's log entry	✓	Own roster only	✗
Delete own log entry	✓	✓	✓
Delete any athlete's log entry	✓	✗	✗
View own workout history	✓	✓	✓
View athlete's workout history	✓	Own roster only	✗
Add session notes / RPE	✓	✓	✓
Attach media to log entry (Premium)	✓	✓	✓

Progress Tracking & Analytics

Action	Admin	Coach	Athlete
View platform-wide analytics	✓	✗	✗
View own progress charts	✓	✓	✓
View assigned athlete's progress	✓	Own roster only	✗
View all athletes' progress	✓	✗	✗
Generate & export PDF progress report	✓	Own roster only	Own only
Set / modify progress goals	✓	Own roster only	Own only
View strength trend charts	✓	✓	✓
View athlete comparison / leaderboard	✓	✓	✗

Notifications

Action	Admin	Coach	Athlete
Receive transactional & security alerts	✓	✓	✓
Send platform-wide announcement	✓	✗	✗
Send message to athlete	✓	Own roster only	✗
Send message to coach	✓	✗	✓
Manage own notification preferences	✓	✓	✓
Manage another user's notifications	✓	✗	✗

Billing & Subscriptions

Action	Admin	Coach	Athlete
View own subscription plan	✓	✓	✓
Upgrade / downgrade plan	✓	✓	✓
Manage payment method	✓	✓	✓
View own invoice history	✓	✓	✓
View all org billing — platform-wide	✓	✗	✗
Apply discount codes	✓	✓	✓
Issue refunds	✓	✗	✗

Admin Portal & System Settings

Action	Admin	Coach	Athlete
Access Admin Portal	✓	✗	✗
View audit logs (2-year retention)	✓	✗	✗
Configure global system settings	✓	✗	✗
Manage global exercise / content library	✓	✗	✗
View platform usage metrics	✓	✗	✗
Configure subscription tier limits	✓	✗	✗
Manage CMS & dynamic assets	✓	✗	✗

DELIVERABLE 02 OF 07

Free vs Premium Tier Comparison

Complete feature gate matrix — required for Stripe configuration and developer feature-flag implementation.

Dev Note: Premium-gated features must return `HTTP 403 upgrade_required` when a Free user attempts access. Free-tier limits must be enforced at the API layer, not only in the UI.

Plan Overview

Feature	Free	Premium
Monthly Price	$0 / month	$X / month (TBD)
Target User	Solo athletes, trial users	Coaches, serious athletes, teams
Support Level	Community / Email	Priority email + in-app chat
Billing Cycle	N/A	Monthly or Annual

User & Roster Limits

Feature	Free	Premium
Athletes per coach	3 max	Y Unlimited
Organization / team accounts	✗	✓
Multi-coach organization	✗	Y (Add-on)
External collaborator invites	✗	✓

Athlete Profile

Feature	Free	Premium
Basic profile (name, age, bio, avatar)	✓	✓
Biometric & health data tracking	3 metrics	Y Unlimited
Active goals	1 goal max	Y Unlimited
Custom profile fields	✗	✓
Profile export as PDF	✗	✓

Workout Library & Templates

Feature	Free	Premium
Access global exercise library	✓	✓
Create custom exercises	5 max	Y Unlimited
Create workout templates	3 max	Y Unlimited
Upload exercise media (video / image)	✗	✓
Duplicate / clone templates	✗	✓
Template tagging & categorisation	✗	✓
Share templates with athletes	1 template	Y Unlimited

Workout Assignment & Scheduling

Feature	Free	Premium
Assign workouts to athletes	Max 3 athletes	Y Unlimited
Calendar scheduling view	Week view only	Y Full calendar
Recurring workout scheduling	✗	✓
Training block / periodisation	✗	✓
Rest day & recovery scheduling	✓	✓

Workout Logging

Feature	Free	Premium
Log workouts (sets / reps / weight / RPE)	✓	✓
Session notes	✓	✓
Attach media to log entry	✗	✓
Coach log on behalf of athlete	✗	✓
Workout log history retention	30 days only	Y Unlimited
Edit past log entries	Within 24 hrs	Y Unlimited

Progress Tracking & Analytics

Feature	Free	Premium
Dashboard summary & progress charts	Y Basic	Y Advanced
Strength trend visualisation	1 metric / 7 days	Y All metrics / all time
Volume load tracking	✗	✓
Body composition tracking	✗	✓
Athlete comparison leaderboard	✗	✓
Generate & export PDF progress report	✗	✓
Automated weekly summary email	✗	✓

Notifications

Feature	Free	Premium
In-app & transactional email	✓	✓
Workout reminder emails	✗	✓
Weekly coach summary emails	✗	✓
Custom notification preferences	✗	✓
SMS / Slack / Teams (future)	✗	Roadmap

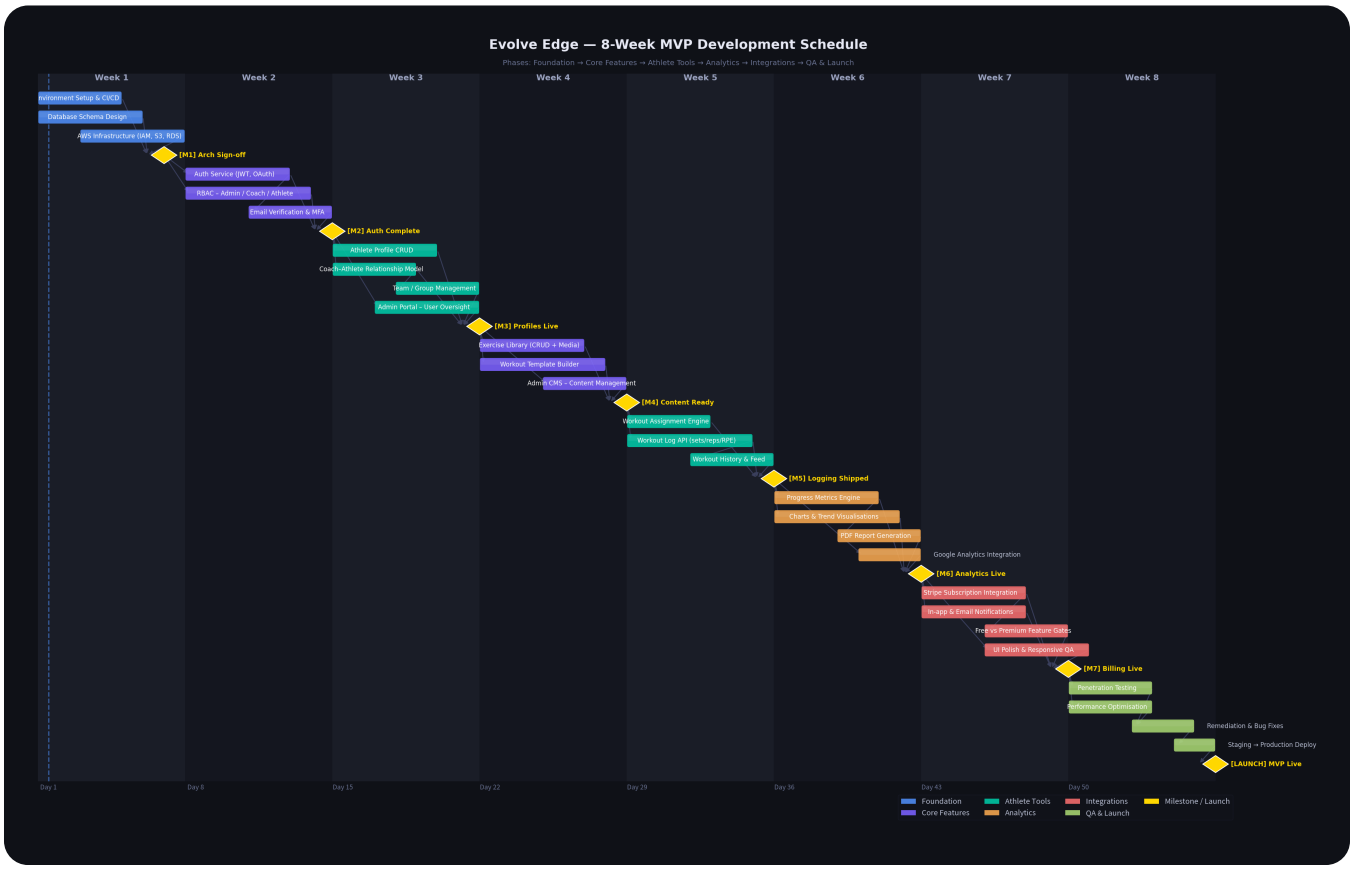
Security & Data

Feature	Free	Premium
AES-256 encryption & TLS 1.2+	✓	✓
Social login (Google / Microsoft)	✓	✓
Optional MFA	✓	✓
Audit log access	✗	✓
Data export / portability	✗	✓
Data retention after account closure	30 days	Y 1 year

DELIVERABLE 03 OF 07

8-Week Development Schedule

Visual Gantt chart with phased milestones, task dependencies, and weekly gate criteria.



Milestone Gate Summary

M1 **Architecture Sign-off**
End of Week 1

AWS provisioned · DB schema approved · CI/CD pipeline green · all environment access confirmed

M2 **Auth Complete**
End of Week 2

JWT auth · RBAC for all 3 roles · MFA (OTP + Authenticator) · Social login (Google, Microsoft)

M3 **Profiles Live**
End of Week 3

Athlete CRUD · Coach–Athlete relationships · Team management · Admin user oversight live

M4 **Content Ready**
End of Week 4

Exercise library with media · Workout template builder · CMS for dynamic assets live

M5 **Logging Shipped**
End of Week 5

Workout assignment engine · Full log API (sets/reps/RPE) · Workout history feed functional

M6 **Analytics Live**
End of Week 6

Progress metrics engine · Charts & trends · PDF report generation · Google Analytics

M7 **Billing Live**
End of Week 7

Stripe end-to-end · Free/Premium feature gates · Email & in-app notifications · Responsive QA

GO **MVP Launch**
End of Week 8

All high/medium pen-test findings resolved · Perf optimisation complete · Staging → Prod deploy

Phase & Critical Path

Phase	Weeks	Key Deliverables	Blocks If Late
Foundation	1	Env setup, DB schema, AWS, CI/CD	Everything
Core Features	2 & 4	Auth/RBAC, Exercise Library, Templates	Profile & Logging phases
Athlete Tools	3 & 5	Profiles, Teams, Workout Logging	Analytics & reporting
Analytics	6	Progress metrics, Charts, PDF reports	Billing feature gates
Integrations	7	Stripe, Notifications, Feature flags	Launch readiness
QA & Launch	8	Pen test, optimisation, production deploy	—

Critical Path: Foundation → Auth → Profiles → Workout Library → Logging → Analytics → Billing → QA → Launch. Each milestone is a hard gate — the next phase does not begin until the current gate is signed off.

DELIVERABLE 04 OF 07

API Endpoint Specifications

Complete REST API contracts for Athlete Profiles, Workout Logging, and Progress Tracking.

Base URL: `https://api.evolveedge.io/v1` · **Auth:** `Authorization: Bearer <JWT>` on all endpoints · **Rate Limit:** 100 req/min per user · 500 req/min per org

SECTION 4A

Athlete Profile Endpoints

GET `/athletes`

Paginated athlete list. Coaches see only assigned athletes. Admins see all.

Param	Type	Required	Description
page	integer	No	Default 1
limit	integer	No	Default 20, max 100
search	string	No	Filter by name or email
coach_id	UUID	No	Filter by coach (Admin only)
status	enum	No	active | inactive | archived

POST `/athletes`

Create a new athlete. Admin or Coach only. Free tier: max 3 athletes per coach.

REQUEST BODY

```
{ "first_name":"Jordan", "last_name":"Smith", "email":"jordan@email.com",
  "coach_id":"uuid", "date_of_birth":"1998-04-22", "sport":"Powerlifting",
  "experience_level":"intermediate", "goals":["increase_strength"] }
```

Error Code	Reason
400	Missing required field
409	Email already registered
403	Free tier roster limit reached (max 3)

GET `/athletes/{athlete_id}`

Full athlete profile. Coach must be assigned. Athletes access own profile only.

RESPONSE 200 OK

```
{ "id":"uuid", "first_name":"Jordan", "last_name":"Smith",
  "email":"jordan@email.com", "sport":"Powerlifting",
  "experience_level":"intermediate",
  "coach":{"id":"uuid","name":"Alex Turner"},
  "goals":[{"id":"uuid","title":"Hit 200kg squat","target_date":"2026-06-01","status":"active"}],
  "biometrics":{"height_cm":178,"weight_kg":88.5,"body_fat_pct":14.2},
  "subscription_tier":"premium", "status":"active" }
```

PATCH `/athletes/{athlete_id}`

Partial profile update. Athletes update own fields; Coaches update assigned athletes; Admins update all. Returns full updated profile.

DELETE `/athletes/{athlete_id}`

Soft-delete (archive). Admin only. Data retained 30 days, then anonymised per HIPAA. Returns `409` if athlete has active workloads.

POST `/athletes/{athlete_id}/goals`

Create a goal. Free: max 1 active goal. Premium: unlimited.

REQUEST BODY

```
{ "title":"Hit 200kg squat", "category":"strength", // strength|endurance|body_comp|performance
  "target_value":200, "unit":"kg", "target_date":"2026-06-01" }
```

SECTION 4B

Workout Logging Endpoints

POST `/workout-logs`

Log a completed session. Self-log or coach-on-behalf (Premium only).

REQUEST BODY

```
{ "athlete_id":"uuid", "workout_template_id":"uuid", "assignment_id":"uuid",
  "date":"2026-03-19", "start_time":"07:30:00", "end_time":"08:45:00",
  "status":"completed", "overall_rpe":8,
  "session_notes":"Felt strong on squats. Lower back tight on deadlifts.",
  "exercises":[{
    "exercise_id":"uuid", "exercise_name":"Back Squat", "order":1,
    "sets":[
      {"set_number":1,"reps":5,"weight_kg":150,"rpe":7,"completed":true},
      {"set_number":2,"reps":5,"weight_kg":155,"rpe":8,"completed":true},
      {"set_number":3,"reps":4,"weight_kg":160,"rpe":9,"completed":true,"notes":"grinder"}
    ]
  },{
    "exercise_id":"uuid", "exercise_name":"Romanian Deadlift", "order":2,
    "sets":[
      {"set_number":1,"reps":8,"weight_kg":100,"rpe":6,"completed":true},

{"set_number":3,"reps":6,"weight_kg":100,"rpe":8,"completed":false,"skip_reason":"lower_back_fatigue"}
    ]
  }],
  "media_urls":["https://cdn.evolveedge.io/logs/video.mp4"] // Premium only
}
```

Field	Type / Constraints	Notes
overall_rpe	integer 1–10	Session Rate of Perceived Exertion
weight_kg	decimal > 0	Use 0 for bodyweight exercises
skip_reason	enum	time | fatigue | injury | lower_back_fatigue | other
media_urls	array	Premium only · max 5 files · 100 MB each

GET `/workout-logs`

Paginated history. Free: from_date limited to last 30 days (403 upgrade_required if exceeded). Role-scoped.

Param	Description
athlete_id (UUID)	Coach/Admin only
from_date / to_date	ISO 8601 date range
exercise_id (UUID)	Filter logs containing specific exercise
status	completed | partial | skipped
page / limit	Pagination — max 50 per page

PATCH `/workout-logs/{log_id}`

Update a logged session. Free Athlete: edit window is 24 hours only (403 after). Coach/Admin: unlimited.

POST `/workout-logs/{log_id}/media`

Attach media to log entry. ***Premium only.*** `multipart/form-data`*. Max 5 files · 100 MB/file · 500 MB/log total. Supported: MP4, MOV, JPG, PNG.*

SECTION 4C

Progress Tracking Endpoints

GET `/athletes/{athlete_id}/progress/summary`

Dashboard summary card — sessions, volume, streaks, PRs, goal progress.

RESPONSE 200 OK


```
{ "athlete_id":"uuid", "period":"last_30_days",
  "total_sessions":18, "total_volume_kg":74200,
  "avg_session_duration_minutes":68, "avg_rpe":7.4,
  "workouts_completed_pct":90,
  "personal_records":[{"exercise_name":"Back Squat","value_kg":182.5,"achieved_date":"2026-03-15"}],
  "streak":{"current_days":12,"longest_days":21},
  "goal_progress":[{"title":"Hit 200kg
squat","current_value":182.5,"target_value":200,"progress_pct":91.25}] }
```


GET `/athletes/{athlete_id}/progress/strength`

Strength progression data for chart rendering. ***Premium only.***

Param	Description
exercise_id	Required
metric	1rm_estimated | max_weight | total_volume
from_date / to_date	Date range
interval	day | week | month

GET `/athletes/{athlete_id}/progress/volume`

Weekly/monthly training volume (sets × reps × weight) for load management. Params: from_date, to_date, interval (week\|month), exercise_id (optional).

GET `/athletes/{athlete_id}/progress/body-composition`

Body composition trend (weight, body fat %, lean mass). ***Premium only.*** *Returns data_points array + trend deltas.*

GET `/athletes/{athlete_id}/progress/report`

Structured progress report. Returns JSON or downloadable PDF. ***Premium only.***

Param	Description
from_date / to_date	Report period
format	json | pdf (default: json)
include_sections	summary, strength, volume, body_comp, goals, recommendations

POST `/athletes/{athlete_id}/progress/biometrics`

Record new biometric measurement. Returns entry with calculated lean_mass_kg.

REQUEST BODY

```
{ "weight_kg":88.5, "body_fat_pct":14.2, "height_cm":178,
  "recorded_at":"2026-03-19T08:00:00Z", "notes":"Morning fasted" }
```

GET `/progress/leaderboard`

Coach's athlete rankings by volume, sessions, or streak. ***Premium only.*** *Params: coach_id, metric (volume\|sessions\|streak), period (week\|month).*

API Error Reference

Code	Error Key	Meaning
400	`validation_error`	Missing or invalid request field
401	`unauthorized`	Missing or expired JWT
403	`forbidden`	Valid token, insufficient role/tier
403	`upgrade_required`	Premium-gated feature
404	`not_found`	Resource does not exist or not accessible
409	`conflict`	Duplicate email, active workloads, etc.
429	`rate_limit_exceeded`	100 req/min exceeded — retry after cooldown
500	`internal_error`	Server-side failure — log and retry with backoff

DELIVERABLE 05 OF 07

User Story Cards

33 user stories across 9 modules, each with role, feature description, benefit, and acceptance criteria.

Priority Tags: **P1 Critical** must ship in MVP **P2 Important** should ship in MVP **P3 Nice-to-have** can be deferred

Authentication & Account Management

US-AUTH-01 ATHLETE

*"As a **Athlete**, I want **register with email/password and verify my email**,*
so that my account is confirmed and secure before I can access the platform."

ACCEPTANCE CRITERIA

- Registration form accepts all required fields (name, email, password, DOB)
- Verification email is sent within 60 seconds of registration
- Unverified account cannot access any authenticated route
- Verified account is granted full access immediately after clicking link

P1 Critical **All Tiers**

US-AUTH-02 ANY USER

*"As a **Any User**, I want **login with my Google or Microsoft account**,*
so that I can access the platform without managing a separate password."

ACCEPTANCE CRITERIA

- Google OAuth flow completes and creates/links account
- Microsoft OAuth flow completes and creates/links account
- Returning OAuth user is recognised and logged in without re-authorising
- First-time OAuth login prompts for any missing required fields

P1 Critical **All Tiers**

US-AUTH-03 ANY USER

*"As a **Any User**, I want **enable Multi-Factor Authentication on my account**,*
so that my data is protected with an additional layer of security."

ACCEPTANCE CRITERIA

- MFA can be enabled via Authenticator app (TOTP) or Email OTP
- MFA setup shows QR code or sends setup email correctly
- Once enabled, MFA is required at every login
- Admin Portal always requires MFA — this cannot be disabled

P1 Critical **All Tiers**

US-AUTH-04 ADMIN

*"As a **Admin**, I want **force-logout any user and reset their session**,*
so that I can respond immediately to suspected security incidents."

ACCEPTANCE CRITERIA

- Admin can select any active user and invalidate their JWT
- Force-logout is recorded in the audit log with timestamp and admin ID
- Affected user receives a security notification email
- Force-logout takes effect within 60 seconds

P2 Important **All Tiers**

Athlete Profiles

US-PROF-01 COACH

*"As a **Coach**, I want **create a detailed athlete profile with health and biometric data**,*
so that I have a complete baseline picture of each athlete before programming begins."

ACCEPTANCE CRITERIA

- Profile form captures name, DOB, sport, experience level, and goals
- Biometric fields include height, weight, body fat % with timestamp
- Free tier blocks creation of a 4th athlete with a clear upgrade prompt
- New athlete receives an invite email to activate their account

P1 Critical | All Tiers

US-PROF-02 ATHLETE

*"As a **Athlete**, I want **update my own biometric measurements regularly**,*
so that my progress data stays current and accurate over time."

ACCEPTANCE CRITERIA

- Athlete can add a new biometric entry at any time
- All historical entries are retained and timestamped
- Free tier: only 3 metric types tracked (e.g., weight, height, body fat)
- Premium: unlimited metric types including custom fields

P1 Critical | Free + Premium

US-PROF-03 COACH

*"As a **Coach**, I want **set specific, measurable goals for each of my athletes**,*
so that we have clear, trackable targets to measure progress against."

ACCEPTANCE CRITERIA

- Goal includes title, target value, unit, and target date
- Goal status updates automatically as progress is tracked
- Free tier: 1 active goal per athlete; Premium: unlimited
- Goal completion triggers a notification to both coach and athlete

P1 Critical | All Tiers

US-PROF-04 ADMIN

*"As a **Admin**, I want **export any athlete's complete profile as a formatted PDF**,*
so that I can provide official records for compliance, legal, or reporting purposes."

ACCEPTANCE CRITERIA

- Export includes profile data, biometrics history, and goals
- PDF is formatted with platform branding and generation timestamp
- Export action is recorded in the audit log
- File download initiates immediately on request

P2 Important | Premium Only

Workout Library

US-LIB-01 COACH

*"As a **Coach**, I want **create custom exercises with descriptions, muscle groups, and instructional media**, so that athletes understand exactly how to execute each movement correctly."*

ACCEPTANCE CRITERIA

- Exercise form captures name, description, primary/secondary muscles
- Video or image can be uploaded and attached (Premium)
- Free tier: max 5 custom exercises; 6th creation blocked with upgrade prompt
- Created exercises are visible to all assigned athletes in the library

P1 Critical | All Tiers

US-LIB-02 COACH

*"As a **Coach**, I want **build reusable workout templates with ordered exercises and set/rep targets**, so that I can efficiently assign structured programmes to multiple athletes at once."*

ACCEPTANCE CRITERIA

- Template builder allows adding multiple exercises with drag-to-reorder
- Each exercise slot specifies sets, target reps, and target weight or %1RM
- Free tier: max 3 templates; Premium: unlimited + cloning
- Template can be duplicated and modified for different athlete levels

P1 Critical | All Tiers

US-LIB-03 ATHLETE

*"As a **Athlete**, I want **browse the global exercise library and view instructions for assigned exercises**, so that I can prepare for my workouts and perform each exercise safely."*

ACCEPTANCE CRITERIA

- Library is searchable by name, muscle group, and equipment
- Each exercise shows description, media, and muscle diagram
- Athlete can view full library (read-only) — no creation access
- Assigned exercises are highlighted in the athlete's view

P2 Important | All Tiers

US-LIB-04 ADMIN

*"As a **Admin**, I want **manage and curate the global exercise library for all users**, so that the platform maintains a high-quality, standardised exercise database."*

ACCEPTANCE CRITERIA

- Admin can edit or delete any exercise created by any user
- Admin can mark exercises as 'global' to make them available to all
- Global exercises cannot be deleted by coaches
- Changes to global exercises are logged in the audit trail

P2 Important | All Tiers

Workout Assignment & Scheduling

US-ASGN-01 COACH

*"As a **Coach**, I want **assign a workout template to an athlete with a specific scheduled date**, so that each athlete has a clear, structured training plan to follow."*

ACCEPTANCE CRITERIA

- Assignment links a template to an athlete with a target date
- Athlete sees assigned workout in their calendar and upcoming view
- Coach can assign to any athlete on their roster
- Free tier: assignment limited to max 3 athletes

P1 Critical | All Tiers

US-ASGN-02 COACH

*"As a **Coach**, I want **configure recurring weekly workout schedules for my athletes**, so that training blocks are auto-populated without manual re-assignment each week."*

ACCEPTANCE CRITERIA

- Coach can define a repeating schedule (e.g., Mon/Wed/Fri)
- Workouts auto-generate on the defined schedule for a set duration
- Individual sessions can be overridden without affecting the recurring rule
- Recurring schedule feature is Premium only

P2 Important | Premium Only

US-ASGN-03 ATHLETE

*"As a **Athlete**, I want **view my full training schedule on a weekly and monthly calendar**, so that I can plan my time, rest, and nutrition around my training plan."*

ACCEPTANCE CRITERIA

- Calendar view shows all assigned workouts by date
- Free tier: week view only; Premium: full month calendar
- Completed workouts are marked differently from upcoming ones
- Athlete can tap a session to see its full exercise details

P1 Critical | All Tiers

Workout Logging

US-LOG-01 ATHLETE

*"As a **Athlete**, I want **log a completed workout with sets, reps, weight, and RPE for each exercise**, so that my training data is accurately recorded for coach review and progress tracking."*

ACCEPTANCE CRITERIA

- Log captures sets, reps, weight (kg), and RPE per set
- Overall session RPE and duration are recorded at the session level
- Skipped sets record a skip_reason from a defined list
- Total volume (sets×reps×weight) is auto-calculated on save

P1 Critical | All Tiers

US-LOG-02 ATHLETE

*"As a **Athlete**, I want **add session notes to document how I felt during a workout**, so that my coach can understand the context behind my performance data."*

ACCEPTANCE CRITERIA

- Notes field accepts free text up to 1,000 characters
- Notes are visible to the assigned coach
- Notes are included in progress report exports
- Notes can be edited by athlete within 24 hrs (Free) or unlimited (Premium)

P1 Critical | All Tiers

US-LOG-03 COACH

*"As a **Coach**, I want **log a workout session on behalf of an assigned athlete**,*
so that in-person coached sessions are recorded even when the athlete has no device."

ACCEPTANCE CRITERIA

- Coach can initiate a log on behalf of any assigned athlete
- Log appears in athlete's history attributed to the session date
- Coach-entered logs are labelled as 'logged by coach' in the history
- This feature is Premium only — 403 returned for Free tier coaches

P2 Important | Premium Only

US-LOG-04 ATHLETE

*"As a **Athlete**, I want **attach a video clip to my log entry for technique review**,*
so that my coach can review my form remotely and provide targeted feedback."

ACCEPTANCE CRITERIA

- Video upload accepts MP4 and MOV formats
- Max 5 attachments per log, 100 MB per file
- Upload progress indicator shown during upload
- Video is accessible to the assigned coach for the life of the log

P3 Nice-to-have | Premium Only

Progress Tracking & Analytics

US-PROG-01 ATHLETE

*"As a **Athlete**, I want **see a dashboard summary of my training activity for the last 30 days**,*
so that I can quickly assess my consistency and performance without digging through logs."

ACCEPTANCE CRITERIA

- Dashboard shows total sessions, total volume, avg RPE, and completion %
- Current training streak and all-time longest streak are displayed
- Personal records achieved in the period are highlighted
- Goal progress bars show % achieved toward each active goal

P1 Critical | All Tiers

US-PROG-02 COACH

*"As a **Coach**, I want **view strength progression charts for each of my athletes over time**,*
so that I can identify performance trends, plateaus, and when to adjust programming."

ACCEPTANCE CRITERIA

- Chart plots estimated 1RM, max weight, or total volume over selected period
- Free tier: 1 metric, last 7 days only; Premium: all metrics, all time
- Trend direction (increasing/stable/decreasing) and % change shown
- Personal records are marked on the chart timeline

P1 Critical | All Tiers

US-PROG-03 COACH

*"As a **Coach**, I want **generate and export a branded PDF progress report for an athlete**,*
so that I can professionally share progress summaries with athletes and their sponsors."

ACCEPTANCE CRITERIA

- Report includes summary, strength trends, volume, body comp, and recommendations
- PDF is formatted with platform branding and athlete/coach name
- Date range and included sections are configurable before export
- Report generation is Premium only — Free users see upgrade prompt

P2 Important | Premium Only

US-PROG-04 COACH

*"As a **Coach**, I want **view a leaderboard comparing all my athletes by volume and consistency**,*
so that I can identify who needs additional support, motivation, or programme adjustment."

ACCEPTANCE CRITERIA

- Leaderboard ranks athletes by total volume, session count, or streak
- Period filter allows week or month view
- Only coach's own roster is visible — no cross-coach comparison
- Leaderboard is Premium only

P2 Important | Premium Only

US-PROG-05 ATHLETE

*"As a **Athlete**, I want **track my body weight, body fat percentage, and lean mass over time**,*
so that I can see the physical impact of my training and nutrition plan."

ACCEPTANCE CRITERIA

- Body composition chart shows all three metrics over selected period
- New entries can be added at any time with an optional note
- Trend deltas (change since period start) are shown below chart
- Feature is Premium only

P2 Important | Premium Only

Notifications

US-NOTIF-01 ATHLETE

*"As a **Athlete**, I want **receive a reminder notification before each scheduled workout**,*
so that I never miss a session simply because I forgot it was on my schedule."

ACCEPTANCE CRITERIA

- Reminder sent via in-app and email 1 hour before scheduled workout
- Reminder timing is configurable in notification preferences (Premium)
- Reminders are not sent for rest days or cancelled sessions
- Feature is Premium only

P2 Important | Premium Only

US-NOTIF-02 COACH

*"As a **Coach**, I want **receive a notification when an athlete completes or skips a workout**,*
so that I can follow up promptly and adjust programming in response to athlete activity."

ACCEPTANCE CRITERIA

- Notification is sent within 5 minutes of athlete logging a session
- Notification includes athlete name, workout name, and completion status
- Coach can tap notification to navigate directly to the athlete's log
- Notification preferences can be managed per-athlete (Premium)

P2 Important | Premium Only

US-NOTIF-03 ADMIN

*"As a **Admin**, I want **send a platform-wide announcement to all active users**,*
so that I can communicate important updates, maintenance windows, or new features efficiently."

ACCEPTANCE CRITERIA

- Admin can compose and send a broadcast message from the Admin Portal
- Announcement is delivered via in-app notification banner
- Broadcast is logged in the audit trail with timestamp and admin ID
- Admin can schedule announcements for future delivery

P2 Important | All Tiers

Billing & Subscriptions

US-BILL-01 COACH

*"As a **Coach**, I want **upgrade from Free to Premium directly within the app via Stripe**, so that I can unlock advanced features immediately without leaving the platform."*

ACCEPTANCE CRITERIA

- Upgrade flow opens Stripe-hosted checkout with plan details
- On successful payment, Premium features unlock within 60 seconds
- Subscription confirmation email is sent by Stripe
- Upgrade action is recorded in the platform audit log

P1 Critical | All Tiers

US-BILL-02 ANY USER

*"As a **Any User**, I want **view my full invoice history and download individual invoices as PDFs**, so that I can manage my subscription spending for personal or business accounting."*

ACCEPTANCE CRITERIA

- Invoice list shows date, amount, and payment status
- Each invoice is downloadable as a PDF from the billing settings page
- Failed payments are clearly marked with a retry option
- Invoice data is sourced directly from Stripe

P1 Critical | All Tiers

US-BILL-03 ADMIN

*"As a **Admin**, I want **issue a full or partial refund to any subscriber via the Admin Portal**, so that I can resolve billing disputes quickly and maintain customer satisfaction."*

ACCEPTANCE CRITERIA

- Admin can select any paid invoice and initiate a Stripe refund
- Partial refund amount is configurable
- Refund is processed by Stripe and reflected in user's invoice history
- Refund action is logged in audit trail with reason field

P2 Important | All Tiers

Admin Portal

US-ADMIN-01 ADMIN

*"As a **Admin**, I want **view a comprehensive audit log of all significant user and system actions**, so that I can investigate security incidents, compliance issues, or disputed actions."*

ACCEPTANCE CRITERIA

- Audit log records: login events, data edits, permission changes, report exports
- Each entry includes user ID, action type, timestamp, and IP address
- Logs are searchable and filterable by user, date, and action type
- Logs are retained for a minimum of 2 years

P1 Critical | All Tiers

US-ADMIN-02 ADMIN

*"As a **Admin**, I want **configure subscription tier limits (e.g., max athletes per coach)**, so that feature gates are enforced consistently across the platform without a code deploy."*

ACCEPTANCE CRITERIA

- Tier limits are configurable via Admin Portal settings panel
- Changes take effect immediately without requiring redeployment
- Each tier limit change is logged in the audit trail
- Developer note: limits must be fetched from DB/config at runtime, not hardcoded

P1 Critical | All Tiers

US-ADMIN-03 ADMIN

*"As a **Admin**, I want **view a live dashboard of platform usage metrics**, so that I can monitor platform health, growth, and identify operational issues early."*

ACCEPTANCE CRITERIA

- Dashboard shows: active users (DAU/MAU), sessions logged today, reports generated
- Metrics are refreshed every 5 minutes or on demand
- Time-series graphs show trends over last 7/30/90 days
- Metrics data feeds into Google Analytics and back-end API logs

P2 Important | All Tiers

DELIVERABLE 06 OF 07

Testing Checklist by Milestone

120+ test cases organised by milestone gate. Every item must pass before the milestone is signed off and the next phase begins.

Key: White items = both tiers · **Purple items** = Premium tier only · All tests must be executed on the staging environment before sign-off.

M1

Architecture Sign-off

End of Week 1 · All items must pass before this milestone gate is signed off

INFRASTRUCTURE

- [ ] AWS account configured with correct IAM roles and least-privilege policies
- [ ] S3 buckets created with AES-256 server-side encryption enabled
- [ ] RDS PostgreSQL instance provisioned with automated daily backups enabled
- [ ] VPC, subnets, and security groups correctly configured
- [ ] SSL/TLS certificate installed and verified on all endpoints
- [ ] CloudFront or AWS Shield DDoS protection active

DEVELOPMENT SETUP

- [ ] Database schema reviewed and signed off by lead developer
- [ ] CI/CD pipeline successfully builds and deploys to staging environment
- [ ] Environment variables in AWS Secrets Manager (zero secrets in code)
- [ ] Git repository branch protection rules (require PR review, no direct push to main)
- [ ] All team members confirmed access to dev and staging environments
- [ ] Monitoring and alerting configured (CloudWatch or equivalent)

M2 Auth Complete

End of Week 2 · All items must pass before this milestone gate is signed off

REGISTRATION & EMAIL

- [ ] User can register with email and password — all required fields validated
- [ ] Verification email sent within 60 seconds of registration
- [ ] Unverified account cannot access any authenticated API route
- [ ] Email verification link correctly activates the account
- [ ] Password reset email sent and reset link works end-to-end

LOGIN & SESSIONS

- [ ] Login with correct credentials returns a valid JWT
- [ ] Login with incorrect credentials returns HTTP 401
- [ ] JWT expiry is enforced — expired tokens rejected with 401
- [ ] Rate limiting blocks brute-force login attempts after 10 failures
- [ ] Admin Portal auto-logout fires after 15 minutes of inactivity

SOCIAL LOGIN

- [ ] Google OAuth flow completes and creates/links an account correctly
- [ ] Microsoft OAuth flow completes and creates/links an account correctly
- [ ] Returning OAuth user is recognised and logged in without re-auth prompt

MFA

- [ ] MFA via Authenticator app (TOTP) can be enabled and used successfully
- [ ] MFA via Email OTP can be enabled and used successfully
- [ ] Admin Portal login always requires MFA — bypass attempt returns 403

RBAC

- [ ] Admin JWT can access all Admin Portal routes
- [ ] Coach JWT cannot access Admin Portal routes — returns 403
- [ ] Athlete JWT cannot access Coach or Admin routes — returns 403
- [ ] Coach can only view athletes in their own roster via API
- [ ] Athlete can only access their own profile data via API

M3

Profiles Live

End of Week 3 · All items must pass before this milestone gate is signed off

ATHLETE CRUD

- [ ] Admin can create an athlete and assign to a coach
- [ ] Coach can create an athlete on their roster
- [ ] Coach sees only their own roster (GET /athletes returns scoped results)
- [ ] Admin sees all athletes platform-wide
- [ ] Athlete can view and edit their own profile
- [ ] Coach can edit profile of assigned athlete only

TIER LIMITS

- [ ] Free tier: 4th athlete creation returns HTTP 403 upgrade_required
- [ ] Free tier: 2nd active goal returns HTTP 403 upgrade_required
- [ ] Premium tier: unlimited athletes and goals confirmed

BIOMETRICS & GOALS

- [ ] Biometric data can be added and is timestamped correctly
- [ ] Multiple biometric entries create a history (not an overwrite)
- [ ] Goals display correct progress percentage based on logged data
- [ ] Goal completion triggers notification to coach and athlete

TEAM MANAGEMENT & ADMIN

- [ ] Coach–Athlete relationship is correctly established and visible to both parties
- [ ] Team/group creation and athlete assignment works correctly
- [ ] Admin can view all coaches and their rosters
- [ ] Deactivating a user prevents login — returns 401
- [ ] Admin portal user oversight dashboard loads with live data

M4 Content Ready

End of Week 4 · All items must pass before this milestone gate is signed off

EXERCISE LIBRARY

- [ ] Global exercise library loads with pagination (page, limit params work)
- [ ] Exercise search and filtering by name and muscle group returns correct results
- [ ] Free tier: 6th exercise creation returns HTTP 403 upgrade_required
- [ ] Coach can create exercise with name, description, and muscle groups
- [ ] Admin can edit or delete any exercise

MEDIA UPLOADS

- [ ] Exercise media upload (image) works for Premium coaches
- [ ] Free tier exercise media upload returns HTTP 403 upgrade_required
- [ ] Exercise media upload (video) works for Premium coaches
- [ ] Uploaded media is served via CDN with correct content-type

WORKOUT TEMPLATES

- [ ] Coach can create a workout template with multiple exercises
- [ ] Free tier: 4th template creation returns HTTP 403 upgrade_required
- [ ] Athlete can view templates assigned to them (read-only)
- [ ] Exercises within a template can be reordered
- [ ] Template duplication/cloning works correctly for Premium coaches

CMS

- [ ] Admin CMS can add, edit, and delete dynamic content without redeployment
- [ ] CMS changes are reflected in the app within 60 seconds

M5 Logging Shipped

End of Week 5 · All items must pass before this milestone gate is signed off

ASSIGNMENT ENGINE

- [ ] Coach can assign a workout template to an athlete with a date
- [ ] Athlete sees the assigned workout in their schedule/calendar view
- [ ] Assigned workout shows full exercise details when tapped
- [ ] Coach can cancel/modify an assigned workout
- [ ] Recurring assignment auto-generates sessions on correct dates (Premium)

WORKOUT LOGGING

- [ ] Athlete can log a completed session with full sets/reps/weight/RPE
- [ ] Session notes field saves and displays correctly
- [ ] Skipped sets record skip_reason from the defined enum
- [ ] Total volume (sets × reps × weight) calculated correctly on save
- [ ] Coach can log on behalf of assigned athlete — labelled 'logged by coach'

TIER LIMITS & HISTORY

- [ ] Free tier: workout history beyond 30 days returns HTTP 403 upgrade_required
- [ ] Free tier: editing a log after 24 hours returns HTTP 403 upgrade_required
- [ ] Premium tier: full history accessible and editable at any time
- [ ] Workout history displays in reverse chronological order

MEDIA

- [ ] Video attachment to log entry works for Premium users
- [ ] File size limit (100 MB per file) is enforced — oversized file returns 413
- [ ] Max 5 attachments per log enforced — 6th returns 400

M6

Analytics Live

End of Week 6 · All items must pass before this milestone gate is signed off

DASHBOARD SUMMARY

- [ ] Progress summary returns correct total_sessions and total_volume_kg
- [ ] Personal records correctly detected from log history
- [ ] Current streak calculation is accurate (consecutive logged days)
- [ ] Goal progress percentage is accurate based on latest biometric/log data

CHARTS & TRENDS

- [ ] Strength progression chart renders with correct data points
- [ ] Free tier: chart access limited to 1 metric and 7-day range
- [ ] Premium: all metrics and full date range available
- [ ] Volume trend chart (weekly/monthly) calculates correctly
- [ ] Body composition chart shows weight, body fat, and lean mass over time
- [ ] Trend direction (increasing/stable/decreasing) logic is correct

REPORTS

- [ ] PDF progress report generates with all selected sections
- [ ] PDF download delivers file with correct filename and Content-Type
- [ ] Free tier: report generation returns HTTP 403 upgrade_required
- [ ] Coach leaderboard shows correct rankings for their roster

ANALYTICS TRACKING

- [ ] Google Analytics events fire on all defined page loads
- [ ] User-initiated actions (log workout, export report) fire GA events
- [ ] Backend API metrics are logged correctly for all endpoint calls

M7

Billing Live

End of Week 7 · All items must pass before this milestone gate is signed off

STRIPE INTEGRATION

- [ ] Stripe webhook endpoint verified and receiving events correctly
- [ ] Free user can upgrade to Premium via Stripe checkout flow
- [ ] Premium subscription activates and tier updates in DB within 60 seconds
- [ ] Premium features unlock immediately after subscription activation
- [ ] Subscription cancellation correctly downgrades account to Free
- [ ] Free tier limits re-activate immediately after downgrade

BILLING MANAGEMENT

- [ ] Invoice is generated and emailed on each billing cycle
- [ ] User can view full invoice history in settings
- [ ] User can update their payment method without losing subscription
- [ ] Failed payment triggers in-app and email notification to user
- [ ] Admin can issue a full or partial refund via Admin Portal

NOTIFICATIONS

- [ ] In-app notifications delivered for all defined notification types
- [ ] Transactional emails delivered within 60 seconds of trigger event
- [ ] Workout reminder emails sent at configured time before session (Premium)
- [ ] Coach receives notification when athlete logs or skips a workout (Premium)
- [ ] Custom notification preferences UI saves and applies correctly (Premium)

FEATURE GATES

- [ ] All Premium-gated API endpoints return 403 upgrade_required for Free users
- [ ] All Free-tier limit checks return 403 upgrade_required when exceeded
- [ ] Feature flag values are fetched from DB/config — not hardcoded
- [ ] Upgrading mid-period instantly unlocks all Premium features

AUNC

MVP Launch

End of Week 8 · All items must pass before this milestone gate is signed off

SECURITY & PEN TEST

- [ ] All HIGH and MEDIUM severity pen test findings resolved and re-tested
- [ ] OWASP Top 10 vulnerabilities verified and mitigated
- [ ] git-secrets scan confirms zero secrets or API keys in codebase
- [ ] TLS 1.2+ enforced on all endpoints — TLS 1.0/1.1 blocked
- [ ] AES-256 encryption confirmed active for all data at rest in RDS
- [ ] DDoS protection active and IP blocking/throttling tested

PERFORMANCE & RELIABILITY

- [ ] Load test: 50% of API responses under 100ms
- [ ] Load test: 90% of API responses under 500ms
- [ ] Page load time under 3 seconds on a standard broadband connection
- [ ] Daily backup is running and restore procedure tested end-to-end
- [ ] Health check endpoints operational and returning 200 OK
- [ ] 99% uptime SLA verified in staging over a 7-day monitoring window

DATA & COMPLIANCE

- [ ] Account closure triggers anonymisation after 30 days — tested in staging
- [ ] Audit log entries written correctly for all defined event types
- [ ] Terms of Service, Privacy Policy, and Cookie Policy pages live
- [ ] Cookie consent banner displays and persists preference correctly

PRODUCTION READINESS

- [ ] All environments (dev / staging / prod) correctly separated
- [ ] Production uses live API keys — no test keys in prod environment
- [ ] Error pages (404, 500) are styled and user-friendly
- [ ] End-to-end user journey test: register → create athlete → assign workout → log → progress → upgrade → PDF report
- [ ] All third-party webhooks (Stripe, Google OAuth) pointing to production URLs

DELIVERABLE 07 OF 07

Risk Assessment Matrix

20 identified risks across Technical, Timeline, Budget, and Security categories — each with probability, impact, score, mitigation strategy, and owner.

Risk Score Key: LOW 1–3 | MED 4–6 | HIGH 7–8 | CRIT 9–10 | Score = Probability (1–5) × Impact (1–5) / 2.5

Technical Risks

ID	Category	Risk Description	Prob.	Impact	Score	Mitigation Strategy	Owner
T-01	Technical	Database performance degrades under concurrent user load and complex progress queries	Med	High	High	Use query optimisation, database indexing on (athlete_id, date), connection pooling (PgBouncer), and read replicas for analytics queries. Conduct load testing at M6.	**Backend Dev**
T-02	Technical	N+1 query issues in athlete roster and progress endpoints cause latency spikes	Med	Med	Med	Enforce ORM query auditing in CI pipeline. Use eager loading (select_related / joinedload). Monitor slow query log during development.	**Backend Dev**
T-03	Technical	PDF progress report generation fails or times out for large datasets	Low	Med	Low	Use async background job for PDF generation. Return a job ID and poll for completion. Cap date range for Free tier to reduce payload size.	**Backend Dev**
T-04	Technical	File upload handling introduces security vulnerability (malicious file upload)	Low	High	Med	Validate MIME type and file signature server-side (not just extension). Scan uploads with ClamAV or equivalent. Store in isolated S3 bucket. Never execute uploaded files.	**DevSecOps**
T-05	Technical	JWT token vulnerabilities (algorithm confusion, weak secret) enable unauthorised access	Low	High	Med	Use RS256 (asymmetric) signing. Store private key in AWS Secrets Manager. Set short expiry (15 min) + refresh token pattern. Validate algorithm in every middleware.	**Backend Dev**
T-06	Technical	Third-party OAuth provider (Google/ Microsoft) API changes break login flow	Low	Med	Low	Pin OAuth library versions. Monitor provider changelogs. Implement fallback email/ password login. Set up automated OAuth flow test in CI.	**Frontend Dev**

Timeline Risks

ID	Category	Risk Description	Prob.	Impact	Score	Mitigation Strategy	Owner
TL-01	Timeline	Scope creep from stakeholder feature requests mid-development delays milestone gates	High	High	Crit	Enforce a formal change control process. New features added to a post-MVP backlog. All milestone scope is frozen at project kickoff. PM signs off on any scope changes.	**Product Manager**
TL-02	Timeline	Developer unavailability (illness, competing priorities) causes week-level delays	Med	High	High	Maintain shared documentation for all in-progress work. Two developers must understand each module. Build 2-day buffer into each milestone. Escalate at 1-day slip.	**Tech Lead**
TL-03	Timeline	Pen test findings in Week 8 are more severe than expected and require significant remediation	Med	High	High	Conduct internal security review at M7 (Week 7). Begin pen test no later than Day 50. Triage findings immediately — categorise and assign before pen test report is finalised.	**DevSecOps**
TL-04	Timeline	Stripe integration takes longer than estimated due to webhook complexity and edge cases	Med	Med	Med	Allocate 5 days (not 3) for Stripe in Week 7. Use Stripe's official SDK. Test with Stripe CLI locally before staging. Build simple subscription model first, add complexity iteratively.	**Backend Dev**
TL-05	Timeline	Underestimated complexity of progress tracking calculations (1RM estimation, volume) causes Week 6 overrun	Med	Med	Med	Define all calculation formulae (e.g., Epley 1RM formula) in the spec before development begins. Build and unit-test the calculation engine in Week 5 in parallel with logging.	**Backend Dev**
TL-06	Timeline	UI design revisions after front-end implementation require significant rework	Med	Med	Med	Complete all UI designs/ wireframes and get stakeholder approval before Week 2. Use a UI component library (e.g., shadcn/ui) to accelerate implementation and reduce bespoke styling.	**Frontend Dev**

Budget Risks

ID	Category	Risk Description	Prob.	Impact	Score	Mitigation Strategy	Owner
B-01	Budget	AWS infrastructure costs exceed $200/month target for first 1,000 users	Med	Med	Med	Use serverless compute (AWS Lambda) and managed services to pay-per-use. Set AWS Budgets alerts at $150/month. Review compute sizing after M3. Use RDS t3.micro for MVP.	**DevOps / PM**
B-02	Budget	S3 media storage and CDN costs spike due to large video uploads from Premium users	Med	Med	Med	Enforce strict file size limits (100 MB/file, 500 MB/log). Implement S3 lifecycle policies to move old media to S3 Glacier after 90 days. Monitor S3 costs weekly in first month post-launch.	**DevOps**
B-03	Budget	Additional developer hours from scope changes or defect remediation exceed project budget	Med	High	High	Define fixed-scope MVP contract. Track hours weekly. Escalate to PM if >10% over-budget. Maintain post-MVP backlog to absorb new requests without impacting current sprint.	**Product Manager**
B-04	Budget	Third-party service costs (Stripe fees, email delivery) higher than modelled at scale	Low	Low	Low	Model Stripe fees (2.9% + $0.30) into pricing before launch. Use SES for email delivery ($0.10/1,000 emails). Review cost models at 500 and 1,000 users.	**Product Manager**

Security & Compliance Risks

ID	Category	Risk Description	Prob.	Impact	Score	Mitigation Strategy	Owner
S-01	Security	Data breach exposing athlete biometric and health data (HIPAA-regulated)	Low	High	High	Encrypt all data at rest (AES-256) and in transit (TLS 1.2+). Apply strict RBAC. Pen test before launch. Implement intrusion detection (AWS GuardDuty). Have incident response plan documented before launch.	**DevSecOps**
S-02	Security	Broken Object Level Authorisation (BOLA) allows users to access other users' data via manipulated IDs	Med	High	Crit	Enforce ownership checks in every API handler (not just middleware). Write automated BOLA tests for every CRUD endpoint. Include BOLA-specific test cases in pen test scope. Code review all data access patterns.	**Backend Dev**
S-03	Security	Insufficient input validation enables SQL injection or XSS attacks	Low	High	Med	Use parameterised queries / ORM exclusively (no raw SQL with user input). Sanitise all user-supplied strings. Implement Content Security Policy headers. Add SAST scan to CI pipeline (e.g., Bandit for Python).	**Backend Dev**
S-04	Security	API keys or Stripe webhook secrets accidentally committed to the code repository	Med	High	High	Enforce git-secrets or truffleHog pre-commit hooks. CI pipeline fails on secret detection. Rotate any exposed secrets immediately. All secrets exclusively in AWS Secrets Manager with 90-day rotation policy.	**DevSecOps**

Risk Heat Map Summary

Risk ID	Description	Final Score	Priority Action
TL-01	Scope creep delays milestone gates	CRITICAL	Freeze scope at kickoff. PM owns change control.
S-02	BOLA vulnerability — unauthorised data access	CRITICAL	Ownership checks on every endpoint. BOLA pen test.
TL-02	Developer unavailability causes delays	HIGH	Shared docs, 2-day milestone buffers.
TL-03	Pen test findings severe in Week 8	HIGH	Internal security review at M7. Begin pen test Day 50.
B-03	Developer hours exceed budget	HIGH	Weekly hour tracking. Fixed-scope contract.
S-01	Health data breach (HIPAA)	HIGH	Encryption + GuardDuty + documented incident plan.
S-04	Secrets committed to git repo	HIGH	Pre-commit hooks + CI secret detection.
T-01	DB performance at scale	HIGH	Indexing + query audit + load test at M6.

Document Complete — Version 2.0. All 7 deliverables are compiled and ready for developer handoff. Recommended next steps: (1) Get developer sign-off on milestone gates, (2) Define LLM prompt templates for AI engine, (3) Finalise subscription pricing, (4) Complete wireframes before Week 2 kickoff.